

פוסט-אקספלויטציה והסלמת הרשאות

מודול 11 — האקינג אתי מהיסוד

◀ מה עושים אחרי ה-Shell הראשוני

◀ Enumeration מקומי

◀ הסלמה ב-Linux וב-Windows

◀ Persistence-1 Looting

איפה אנחנו בשרשרת?

- ◀ השגנו Shell — לרוב משתמש **מוגבל**
- ◀ הערך: הסלמה ל-**root / SYSTEM**
- ◀ שאלת הזהב: "מי אני, מה אני יכול, מה מותקן?"
- ◀ משם → תנועה רוחבית (מודול 12)

ייצוב ה-Shell

Shell גולמי = אין Tab/חצים/Ctrl+ ◀

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

 ◀

shell מלא → `stty raw -echo; fg` ◀

שדרוג ל-shell = **Meterpreter** עשיר ◀

Enumeration — העיקרון

מי אני? `whoami` / `priv` / `id` ◀

מערכת? `systeminfo` / `uname -a` ◀

מה רץ? `tasklist` / `ps aux` ◀

Enumeration = 90% מההסלמה ◀

הסלמה ב-Linux (1)

SUID — `find / -perm -4000` → GTFOBins ◀

sudo -l — מה מותר כ-root ◀

root → `sudo vim -c '!/bin/sh'`: דוגמה: ◀

◀ הכלל: "ברירה" מתוכנית מורשית לפקודה

הסלמה ב-Linux (2)

◀ **Cron** — סקריפט root שכתוב לך

◀ **Kernel** — `uname -a` → searchsploit

◀ **exploits** — Dirty COW, PwnKit ידועים

◀ **Capabilities** — `getcap -r /`

הסלמה ב-Windows

Selmpersonate = Potato — `whoami /priv` ◀

Unquoted Service Path ◀

Weak Service Permissions ◀

SYSTEM-כ **AlwaysInstallElevated** = 1 → MSI ◀

כלי אוטומציה

◀ **LinPEAS / WinPEAS** — סורק מקיף, צובע

◀ **PowerUp.ps1** — misconfigs ב-Windows

◀ **linux-exploit-suggester** — Kernel

◀ ⚠ רועשים — תעד ונקה

Looting — איסוף מידע

crack (מודול 8) → `/etc/shadow` ◀

קובצי קונפיג → סיסמאות DB ◀

מפתחות SSH פרטיים → `id_rsa` ◀

סיסמאות בזיכרון (Windows) → `mimikatz` ◀

Persistence (בהרשאה!)

- Linux: `authorized_keys`, Cron, systemd ◀
- Windows: Run keys, Scheduled Task, שירות ◀
- מדגים ללקוח את **הסיכון האמיתי** ◀
- תמיד מתועד ומוסר בסוף ◀

אתיקה וניקוי

◀ **תעד** כל שינוי שביצעת

◀ **החזר** למצב מקורי (הסר כלים/משתמשים)

◀ אל תמחק לוגים ללא תיאום

◀ ההבדל מפושע = תיעוד והחזרה

סיכום מודול 11

◀ Shell = Post-Exploitation אחרי ה-Shell

◀ מייצבים → מונים → מסלימים → אוספים

◀ Linux: SUID/sudo/Cron · Windows: priv/services

◀ Looting מזין תנועה רוחבית ו-AD

◀ **תרגול** → `practice.md` · **פתרונות** → `solutions.md`